0xCMS shared ISO 27001 / HIPAA implementation plan

Prepared 30 October 2026. Planning baseline: e50a467; findings originated in the readiness assessment. See the ISO matrix and HIPAA matrix for control/evidence distinctions.

Objective and scope

Close the confirmed application and repository-configuration gaps with shared changes that support both standards, then establish verified implementation and operating evidence for 59 ISO controls: the original 27 plus 13 repo-led and 19 hybrid controls. W0-W7 retain the confirmed-gap engineering scope; W8-W14 add deployment verification, organizational processes and evidence-led remediation. The integrated delivery groups G1-G8 below extend those same packages for the additional 32 controls; they are not 32 separate projects. This plan does not treat unverified controls as absent, or earlier "not relevant" placeholders as approved exclusions. Finishing this subset does not alone establish organizational compliance or certification.

Rechecked the affected source while planning. Publication remains permissive without a rule; classification errors produce an empty map; PHI classification does not restrict public media; private file reads lack announcements; mutation audit writes remain best-effort; the production file still comments out AUDIT_BUCKET; sessions have no inactivity expiry.

Existing work to reuse: the current audit feature includes /admin/audit/review, bulk-read/refused-access/contributor signals, archive backlog/health reporting and archive verification. Those are implemented foundations. Alert delivery, accountable review evidence and production configuration still require verification; do not rebuild the review screen. Earlier 44-test results belong to the original review and are not validation of this newer revision.

Priorities and shared control mapping

P0 means a prerequisite for enabling the affected regulated-data path, not a claim that an active incident exists. P1 follows containment and closes accountability/operational gaps. Owners are proposed roles; assign named owners before implementation. Estimates are engineering effort, including focused tests/review, not elapsed calendar time or compliance deadlines.

Order / work package	Priority / finding	Shared change	ISO Annex A mapping	HIPAA mapping supported	Owner / estimate	Dependency
W0 - deployment inventory and containment	P0 / F1-F3, F5	Identify affected data/routes; restrict regulated publication/public files pending fixes; inspect actual archive configuration	A.5.9, A.5.12, A.8.3, A.8.12	§§164.308(a)(1), 164.312(a); applicable disclosure restrictions	Platform + security/privacy / 1-2 days	None
W1 - reliable classification and regulated profile	P0 / F2	Authoritative policy resolution; deny regulated access on missing/failed policy; readiness checks	A.5.12, A.8.15, A.8.16	§§164.308(a)(1), 164.312(b)	Core maintainer / 2-4 days	W0 inventory

Order / work package	Priority / finding	Shared change	ISO Annex A mapping	HIPAA mapping supported	Owner / estimate	Dependency
W2 - private regulated media	P0 / F3	Reject classified PHI from public originals/thumbnails; authorize private delivery before bytes/cache access	A.8.3, A.8.12, A.5.34	§164.312(a); applicable Privacy Rule disclosures	Media/plugin maintainer / 3-5 days	W1; private audit hook from W4a before release
W3 - explicit publication policy	P0 / F1	Host-owned, persistent allowlists and destination approvals; validate the entire snapshot before transfer	A.5.14, A.8.3, A.8.12, A.5.34	§164.312(a); §§164.502, 164.514(d) where applicable	Core/plugin maintainer / 5-8 days	W1; W4b for durable policy-change records
W4a - complete sensitive-read coverage	P0 for PHI delivery / F4	Instrument private file reads/lists/exports with actor and classification; reconcile all sensitive read paths	A.8.15, A.8.16, A.5.28	§§164.312(b), 164.308(a)(1)(ii)(D)	Core/plugin maintainer / 3-5 days	W1; coordinate private-delivery contract with W2
W4b - durable mutation and policy evidence	P1; before regulated writes enabled / F4	Atomic mutation + audit/outbox persistence; idempotent delivery and correct PHI mutation class	A.8.15, A.5.28, A.5.33	§§164.312(b), 164.308(a)(1)(ii)(D)	Core maintainer / 5-8 days	W1; shared event contract agreed with W3
W5 - protected archival and actionable monitoring	P1 / F5	Retry-safe archive sealing, concurrency control, restricted retention, independent checkpoints and alerts	A.5.28, A.5.33, A.8.15, A.8.16	§§164.312(b), 164.308(a)(1)(ii)(D)	Platform + audit maintainer / 4-7 days	W0 live-config check; W4 event contract for end-to-end tests
W6 - inactivity expiration	P1 / application part of F6	Server-side idle limit for regulated sessions, distinct from refresh/absolute lifetime	A.8.5, A.5.18	§164.312(a)(2)(iii)	Auth maintainer + security / 2-4 days	Approved session policy and external-control check
W7 - release and evidence closure	P1 / all confirmed gaps	Fault injection, staging verification, migration/rollback drills and matrix updates	A.8.29, A.8.32; operational evidence for mapped controls	§164.308(a)(8) and verification of safeguards above	Engineering + operations + security / 3-5 days	W1-W6 and deployment evidence

Estimated W0-W7 effort: 28-48 person-days, excluding supplier/legal lead time, large data migrations, external plugin rewrites, independent penetration testing and organization-wide ISMS work. This is not the estimate for the expanded 27-control program. W2/W3/W4 can overlap after shared interfaces are agreed; archive engineering and identity evidence collection can proceed independently. Estimates should be refined after W0; they are not a delivery commitment.

Implementation details and acceptance criteria

W0 - establish the deployment boundary first

Inventory classified page types, registered public media, private prefixes, published copies, direct bucket domains, plugin destinations and actual deployed revision/bindings. Record whether PHI exists in each location; do not infer exposure from the code alone. If affected PHI exists, restrict those paths pending migration, preserve relevant evidence and involve the incident owner for exposure assessment. Keep ordinary public-site functionality where it is demonstrably outside that data boundary.

Done when: named data owners approve the inventory; regulated paths have containment or a documented safe configuration; deployed versus repository archive settings are recorded. This is an operational task, not an instruction to delete data or declare an incident automatically.

W1 - one authoritative policy boundary

Primary files: src/core/db/data-classes.ts, src/core/http/access-log.ts, src/core/schema.sql, src/types.ts; profile validation tools and additive migrations.

- Add an explicit regulated deployment mode and readiness checks. Missing schema, unknown required classifications or policy-read errors must produce a safe unavailable result for affected routes, never silently become "unclassified." Distinguish an intentionally public container from an unknown/unclassified container in this mode.
- Resolve policy before any sensitive body, stream or external transfer starts. A post-handler middleware guard cannot recover bytes already streamed or a plugin request already sent.
- Keep enforcement and neutral policy contracts in core. Optional audit UI must not control whether logging/security policy exists. Reject regulated profile combinations that omit required operational capabilities; ordinary non-regulated profiles retain documented behavior.
- Version policy and constrain changes to authorized administrators. W4b supplies durable events for classification/declassification changes; policy-change failures must not leave an unrecorded downgrade.

Acceptance: missing table, missing binding, invalid classification, query timeout/error and unknown regulated type all deny affected access with no sensitive body. Explicitly public reads work. Both enabled/disabled feature profiles pass. Failure signals contain no PHI.

W2 - authorize private media before delivery

Primary files: src/features/media/routes/public.ts, media upload handlers, src/features/media/security.ts, src/features/plugins/api/files.ts.

- Check classification and existing private markers before public object retrieval, transformation or cache lookup. Deny PHI on both original and thumbnail routes.
- Mark regulated uploads private by default. Provide or reuse an authenticated private route with prefix/object authorization, delegated user or service identity and Cache-Control: no-store. Do not weaken existing plugin scopes to make downloads work.

- Attach W4a audit recording to successful sensitive delivery, with the strict record persisted before streaming begins. Cover supported HEAD/range/list variants as appropriate; negative responses must not expose protected metadata.
- Stage an object migration manifest. Verify public R2 domains and caches independently of Worker routes. Purge controlled exposed caches and replace affected keys when needed; downloaded copies cannot be recalled. Separate buckets where required by the deployment's isolation policy.

Acceptance: anonymous PHI originals/thumbnails fail, including cached paths; authorized private delivery succeeds and is auditable; unauthorized/expired/revoked identities and out-of-scope keys fail; ordinary public assets still render. Direct storage endpoints cannot bypass the selected private boundary.

W3 - approve the complete publication snapshot

Primary files: src/core/publish/projection.ts, src/core/publish/index.ts, src/core/publish/adapter.ts, core policy schema and plugin contribution interfaces.

- Persist a host-owned versioned policy per regulated type, independent of plugin availability. Plugins may propose policies but cannot silently loosen host approval. No rule means deny regulated publication.
- Start with a blanket regulated-publication block as containment, then introduce explicit approved schemas/destinations. Separate a public, approved projection from authorized private data transfers.
- Validate nested objects/arrays and all snapshot components: lect, page names/slugs, tags, pointers and draft metadata. Reject malformed/unknown regulated fields rather than relying on a top-level denylist. Keep legacy behavior only for explicitly public types.
- Enforce once before every adapter side effect, covering single/bulk publish, jobs, retry and resync. Validate the current policy/destination on retry; do not send stale queued snapshots after approval is revoked. Align draft/live comparison with the same projection.
- Record policy changes via W4b, including version and approver without sensitive payloads. Retire or re-project already published copies through a reviewed migration rather than assuming future enforcement cleans old data.

Acceptance: disabled/missing plugin, absent policy, invalid nested data and PHI in metadata all produce zero transfer to any target. Unapproved destinations and revoked policies fail on retries. Approved public projection is stable; drift indicators remain correct; ordinary public publication remains functional.

W4 - make evidence durable and complete

Primary files: src/core/db/audit.ts, src/core/http/access-log.ts, plugin file/page APIs, admin mutation callers, core schema, relevant job/ingest handlers.

W4a: reads. Inventory direct/indirect reads: private files, metadata/listing, pages/history, search/export, WebSockets, jobs, service contributors and downstream consumers. Instrument confirmed omissions first; treat remaining routes as a coverage audit rather than asserting they are all broken. Preserve per-event actor identity and delegation, correct classification, target counts and a restricted full manifest where truncated IDs cannot support investigation. Avoid raw query terms, tokens and document bodies. Define how autonomous service actions map to an accountable service owner.

W4b: mutations. Introduce a shared audit statement/event builder. Where business changes and audit rows share D1, commit them in one supported atomic database operation. Prefer an atomic audit row directly; add an outbox when asynchronous external delivery is needed, with unique event/idempotency keys, bounded retry and failure/backlog visibility. A queue alone is not atomic with a database mutation. For R2/plugin/external side effects, persist intent, execute idempotently and reconcile outcomes; do not claim a cross-service transaction. Re-evaluate authorization when deferred work executes.

Instrument regulated content writes and classification/publication-policy/role changes first. Correct PHI mutation classification and retention class. For authentication events without a business mutation transaction, define durable recording/failure handling separately: preserve logout/revocation during audit failure while recording or alerting through a recoverable mechanism. Don't log a rolled-back action as successful.

Acceptance: inject audit-write failure and confirm no unrecorded regulated D1 mutation commits; crashes/redelivery do not duplicate the business operation; external partial failures remain reconcilable; private reads and representative exports are attributable; audit failure cannot leak a streaming response. Declassification is either committed with evidence or refused.

W5 - finish archival protection and operational delivery

Primary files: src/features/audit/sweep.ts, existing signals.ts/review route, audit schema, deployment configuration and runbooks.

- Verify the production binding before changing it. Provision/configure the intended private archive if missing; prove its access and retention settings rather than relying on source comments.
- Make a segment recoverable if object creation succeeds but seal insertion fails. Freeze the intended segment range in durable state; on retry verify an existing object's contents/hash instead of blindly overwriting. Prevent overlapping concurrent sweep ranges or forks using a durable serialization/claim mechanism.
- Reconcile older orphaned segments, and prune only verified sealed ranges. Test actual bucket-lock behavior before activation. Independently protect trusted checkpoints so the application writer cannot replace both data and its only integrity reference undetected.
- Reuse existing backlog/health/signals and review UI. Connect an approved alert sink or existing SIEM, with bounded PHI-free payloads, delivery retry and escalation. Confirm whether operational review/acknowledgment evidence already exists before adding workflow storage. Alert on classification/audit outages, archive lag, missing buckets and verification failures.
- Set retention from approved policy. Do not hardcode six years for every audit record merely because HIPAA documentation has a six-year requirement.

Acceptance: locked-object crash recovery, duplicate/concurrent sweeps, object/DB outages and missing/corrupt segments all behave safely; no unverified range is pruned. Archive backlog drains under representative peak load. A test signal reaches its owner, is acknowledged and produces retained review evidence. No shared mutable hash ledger is presented as independent tamper protection.

W6 - bound inactivity without breaking revocation

Primary files: src/core/auth/sessions.ts, access guards, core session schema, WebSocket session validation and refresh routes.

Choose an inactivity limit with the security owner; a 15-minute candidate can be evaluated, but is not asserted as a universal standards requirement. Verify external session controls first. Add server-side last-activity/idle-expiry state with atomic expiry checks and bounded write frequency; document the maximum timing tolerance. Enforce it on HTTP, refresh and WebSocket paths. Background refresh/polling and socket keepalives must not perpetually extend an otherwise idle interactive session. Define meaningful activity and clock behavior explicitly.

Preserve the existing absolute lifetime, rotation grace and immediate revocation. Initialize existing sessions conservatively or require sign-in on rollout; do not silently extend old sessions. Fail closed if session state is unavailable.

Acceptance: clock-controlled tests distinguish idle expiry from token/absolute expiry; background refresh cannot keep an idle session alive; concurrent activity cannot revive an expired/revoked session; socket access stops within the documented interval. The addressable-specification decision and any external alternatives are documented separately from the code result.

Sequence, migrations and release gates

1. Contain and prepare: W0; agree classification, event and publication-policy contracts. Start supplier/IdP/archive evidence checks in parallel.

2. Apply additive schemas: core policy/session/event schema and optional archive state where needed. Update owning fragments and regenerate baselines; add explicit migrations for existing installations. Never hand-edit generated registries. Rehearse on a representative restored database.

3. Close disclosure paths: W1, W2, W4a and the initial W3 block. Non-regulated deployments get compatibility tests; affected PHI paths stay restricted until their acceptance tests pass.

4. Complete persistence and policy: W4b and full W3. Implement/test W5 and W6 independently where possible. Do not enable protected writes before their evidence path is durable.

5. Stage and release: W7 verifies the exact release revision and production settings. Enable the regulated mode only after policy inventory and migrations are ready. W0 checks alone cannot prove all deployment controls.

For each package run meaningful fault-injection/negative tests plus affected existing suites. Before integrated release run build, type-check, feature-profile/boundary/generated checks and the full suite. Verify feature-disabled behavior and existing-schema upgrades. Staging checks include login/refresh/logout, private original/thumbnail reads, public assets, single/bulk publishing, plugin reads, job retry, role revocation and archive recovery. Use synthetic regulated records, not production PHI, in tests.

Rollback must retain new private/default-deny boundaries. Use additive schema compatibility and forward fixes; if the old binary would expose regulated data, keep the affected route disabled instead of restoring it. Take an authorized recovery copy before migration, preserve policy/event evidence, and document the operator procedure. This plan does not authorize deployment or destructive migration automatically.

Release exit evidence: acceptance results per package; migration/recovery rehearsal; deployed policy/binding/IAM checks; private endpoint/cache verification; audit crash/retry evidence; acknowledged operational alert; session policy decision. Update matrix rows only with the exact scope demonstrated. "Implemented - source verified" does not become full compliance without operational evidence.

Evidence work kept separate from confirmed fixes

Evidence task	Owner	Decision/output
Cloud/plugin BAA and service eligibility (F7)	Legal/privacy + platform	Signed coverage for actual PHI paths; exclude uncovered destinations from regulated use
IdP MFA, tenant/enrollment restrictions and bypass resistance (external part of F6)	Identity/platform	Deployed policy proof and negative tests; create remediation only if deficient
Job-duty authorization	Security + data owner	Decide whether existing roles suffice or narrower access is needed; scope any new authorization work from this matrix
Independent backup and recovery	Operations	Backup inventory and restore exercise; external backups may already exist
TLS, storage encryption and keys	Platform/security	Actual configuration and key-lifecycle evidence; token hashing is not storage-encryption evidence
ISMS, workforce, physical and incident procedures	Security/privacy + management	Existing records, applicability decisions and owners; separately assess the 66 previously unmapped ISO controls

These are release/assessment dependencies where applicable, not invented software defects. Operational findings can create additional work after inspection. Compliance stakeholders should approve their evidence independently of the engineering implementation review.

Expansion: verified coverage of all 27 assessed ISO controls

Completion target and counting

The original milestone is 27/27 assessed controls implemented and evidenced within the agreed scope. The expanded program target is 59/59, including the additional 32 controls in G1-G8, not 59 controls marked "source verified." Source evidence is appropriate for code; contracts, operations and organizational controls need different evidence. Preserve the current matrix statuses until actual verification is complete. Planning an activity does not upgrade a control. Where applicability is conditional, such as outsourced development, record the assessed decision rather than counting a justified exclusion as an implemented control.

Baseline reconciliation: seven rows already have source-verified implementation; nine have known gaps; eleven have supporting features or missing evidence. W0-W7 address the nine gap rows and can advance monitoring, but those improvements still need the policy and operating evidence below. W8-W14 cover those dependencies and the remaining ten rows, while verifying deployment and operation of the original seven.

Use a closure register with control ID, scope, accountable owner, existing evidence, remaining task, linked work package, acceptance result, evidence location/date, reviewer, next review date and open exceptions. Evidence may live in a restricted GRC/document system: keep only references in this repository, never raw PHI, secrets or confidential contracts. Reuse evidence across both standards without conflating their obligations.

Additional work packages

P2 below means completion after immediate exposure/accountability work, not optional. Any package that reveals an active disclosure risk or mandatory deployment prerequisite moves to P0/P1. Start evidence collection and external dependencies immediately.

Package	Priority / owner	Deliverables and implementation rule	Dependencies and acceptance	HIPAA benefit
W8 - owned inventory and control register	P1 / security lead + data/platform owners	Reconcile databases, media, copies, plugins, identities, suppliers and environments with actual deployment. Record ownership, classification, purpose and lifecycle. Establish the closure register for the original 27 and the 32 added controls, with change-triggered inventory updates.	Extends W0. Owner-approved inventory matches deployed resources; sample a new/change/retired asset through the update process.	Supports risk analysis and complete ePHI scope.
W9 - identity, access and cryptography assurance	P1 / identity + platform/security	Review approved access matrix, joiner/mover/leaver process, privileged accounts, service identities and key/secret lifecycle. Verify IdP MFA and alternate-origin restrictions, TLS/storage encryption and key access. Add narrower authorization or rotation tooling only where the assessment identifies a gap.	W8; W6 for idle-session closure. Demonstrate provisioning, role change and termination; access review closes inappropriate rights; test privileged bypass, session revocation and controlled secret rotation. Approve encryption/key evidence for actual stores and transfers.	Supports workforce/access management, authentication, encryption and transmission safeguards.
W10 - supplier and cloud governance	P1; PHI service eligibility is a release prerequisite / procurement/legal + platform/security	Supplier inventory and risk assessments; executed security agreements/BAAs where applicable; cloud shared-responsibility matrix; approved configurations, service coverage, exit/export/deletion plan and periodic review ownership. Existing valid contracts can satisfy this without new software.	W8; approved services feed W3 destinations and W5 archives. Verify actual service/account coverage, obligations and operating configuration; exercise a representative export/exit step. Unresolved required contract/eligibility remains open, not "covered."	Supports BA arrangements, approved subprocessors and cloud responsibilities.

Package	Priority / owner	Deliverables and implementation rule	Dependencies and acceptance	HIPAA benefit
W11 - backup and continuity	P1 / operations + business owner	Agree business impact, RPO/RTO and emergency operation needs. Verify current backup/recovery first; implement missing independent copies or automation. Cover draft/published D1, private media, necessary DO state, policy/configuration, plugin dependencies and safe credential recovery.	W8/W10; coordinate with W12 retention. Restore synthetic representative data in isolation, check attachments/policy consistency and measure recovery against approved objectives. Record failure handling, owner and retest triggers.	Supports backup, disaster recovery and emergency-mode operation.
W12 - privacy, retention and deletion	P1 for regulated disclosure/retention; P2 for lifecycle completion / privacy lead + data owners + engineering	Approve purposes, transfer rules, retention schedule and holds. Map deletion across current data, versions, trash, files, published copies, exports, plugins and backup expiry. Implement only verified lifecycle omissions; define how restoration respects deletion/holds. Establish applicable individual-request and disclosure procedures with assigned customer/vendor responsibilities.	W8/W10 and W1-W5; coordinate W11. Execute a synthetic record lifecycle and request/deletion test, including hold refusal and downstream confirmation. Verify public/regulated transfer paths against approved purposes. Do not delete held records or promise immediate erasure of retained backups.	Supports permitted disclosure, minimum necessary where applicable, privacy requests and documentation.
W13 - incident readiness, evidence and review	P1 / incident owner + security/operations	Response plan, decision/escalation paths, contacts, evidence preservation/chain of custody and post-incident actions. Integrate existing audit review/signals with alert delivery, review ownership and retained acknowledgments. Set realistic review cadence/response objectives.	W4/W5; W10 supplier contacts; W11 recovery. Run a tabletop and technical alert-to-investigation exercise; retrieve and verify evidence, record decisions and close corrective actions. A dashboard screenshot alone is not operating evidence.	Supports incident procedures, activity review and breach-response preparation.
W14 - secure development and release assurance	P1 gates before release; P2 recurring-process completion / engineering lead + security reviewer	Document security requirements/threat modelling, code review, test acceptance, vulnerability handling, environment separation, branch/CI protection, deployment authorization and rollback. Inspect external CI first. Add missing gates and integrate W1-W6 regressions.	W7; policies/gates can start immediately. Walk one representative change from requirement to reviewed commit, CI, approved deployment and rollback rehearsal. Resolve release-blocking findings and retain evidence of ongoing vulnerability triage.	Supports evaluation, risk management and controlled operation of security safeguards.

Traceability: all 27 controls have an owner and a closure test

ISO control	Control area	Packages	Required evidence to close the assessed scope
A.5.9	Asset inventory	W0, W8	Reconciled, owned inventory and a demonstrated update process
A.5.12	Classification	W1, W8, W12	Approved classification inventory; fail-closed tests; controlled reclassification
A.5.14	Transfers	W3, W10, W12	Approved destination/purpose policy and tested complete-snapshot restrictions
A.5.15	Access policy	W9	Approved access model, implemented restrictions and tested permitted/denied cases
A.5.16	Identity lifecycle	W9	Unique identity assignment and provisioning/change/termination evidence
A.5.17	Authentication credentials	W9	Credential handling/rotation/recovery rules and controlled rotation evidence
A.5.18	Access rights	W6, W9	Access approvals/review and effective demotion/offboarding/revocation tests
A.5.19	Supplier security	W8, W10	Owned supplier inventory, risk assessments and scheduled/triggered reviews
A.5.20	Supplier agreements	W10	Executed applicable security terms and recorded obligations/coverage
A.5.23	Cloud security	W10	Approved service configuration, responsibility matrix and exercised exit procedure
A.5.24	Incident preparedness	W13	Owned response plan, current contacts and completed exercise/corrective actions
A.5.28	Evidence collection	W4, W5, W13	Attributable records, protected integrity evidence and exercised preservation/retrieval
A.5.30	ICT continuity	W11	Approved recovery objectives and successful continuity/recovery exercise
A.5.33	Record protection	W5, W12	Access/retention/hold policy; protected recoverable records; archive/recovery tests
A.5.34	Privacy	W1-W3, W10, W12	Applicable purposes/obligations, protected data paths and exercised privacy procedures
A.8.2	Privileged rights	W9	Reviewed privileged membership, appropriate separation and tested privileged authentication
A.8.3	Information access restrictions	W1, W2, W9	Private media and required record/container restrictions verified in deployment
A.8.5	Authentication	W6, W9	Session and identity assurance policy with idle, revocation and bypass tests

ISO control	Control area	Packages	Required evidence to close the assessed scope
A.8.10	Deletion	W12	Demonstrated end-to-end deletion/expiry and hold handling, including copies
A.8.12	Leakage prevention	W2, W3, W12	Verified public/private boundary, approved transfers and negative disclosure tests
A.8.13	Backups	W11	Controlled recoverable copies and measured successful restore with integrity checks
A.8.15	Logging	W1, W4, W5	Coverage matrix; durable attributable events; failure/retry/retention evidence
A.8.16	Monitoring	W5, W13	Effective signals, delivered alerts and retained review/escalation outcomes
A.8.24	Cryptography	W9	Approved use/key policy and verified transport/storage/key-lifecycle configuration
A.8.25	Secure development	W14	Security requirements/threat review and operating development controls
A.8.29	Security testing	W7, W14	Release-specific negative/security test results, review and defect disposition
A.8.32	Change management	W7, W14	Traceable approved change, protected delivery gates and exercised rollback

Each closure requires an accountable owner and review by someone other than the implementer where practical. Document the actual scope and limitations; unresolved required work or ineffective operation leaves the row open. Risk acceptance records a decision but must not be counted as successful implementation of a missing safeguard. Reviews and evidence refresh continue after initial closure.

Delivery sequence and revised sizing

1. Start now: W8 register; W9-W12 evidence discovery; W13 response ownership; W14 release gates. Do this alongside W0 containment so contracts, restores and access approvals do not become late surprises.

2. Technical remediation: execute W1-W7 in the existing order, feeding tests and deployment results into the register. Approve W9/W10/W12 policies before dependent regulated paths are enabled.

3. Operating proof: run access review/offboarding, recovery, record lifecycle, incident/alert and change-control exercises. Reuse existing compliant processes and supplier evidence rather than building duplicate systems.

4. 27-control review: assess all traceability rows, resolve findings and obtain owner/reviewer sign-off. Publish achieved counts separately from planned counts. Keep open rows visible with owners and dates.

W8-W14 are evidence-led: scope existing processes first, then estimate remediation. Reserve a preliminary 20-40 additional person-days across engineering, security, operations and privacy/procurement for register/policy work, verification and exercises if the underlying platforms/processes largely exist. Combined

planning allowance is 48-88 person-days. This excludes contract negotiation/provider eligibility delays, major new backup/access-control systems, extensive supplier remediation and independent assessment fees/lead time. Re-estimate after the initial evidence inventory; no fixed completion date is defensible yet. Operating-history needs depend on actual review cadence and assessment scope, not an invented universal observation period.

The 48-88 person-day allowance above covers the original 27-control milestone only. The integrated expansion below supersedes the former 27-only program scope. The other 34 controls (17 documentation/process and 17 principally external), plus ISO clauses 4-10, still require their own applicability and ISMS work. Some W8-W14 deliverables may help them, but they are not silently added to the 59-control completion count. This plan supplies reusable HIPAA evidence without asserting coverage of every HIPAA requirement.

Integrated expansion: 13 repo-led and 19 hybrid controls

Delivery groups, priorities and ownership

These groups extend existing work. Inspect current implementations and external services before coding; newer regulated publication/media code was observed at 2e6965e. Do not rebuild completed safeguards. R means repo-led; H means hybrid. Each added control is assigned once to a primary group in the traceability table below, even when multiple packages contribute.

Group	Priority and existing packages	Integrated deliverables	Accountable / external owners	Dependencies and release condition
G1 - supply chain, advisories and approved artifacts	P1; W8, W10, W14	One dependency/plugin inventory feeds SBOM/provenance, licence notices, advisory correlation, dependency/SAST/secret checks and approved-artifact deployment. Extend the same contributor pipeline for outsourced developers where applicable. Record finding owner, severity, disposition and expiring exceptions.	Engineering/security; procurement/legal, Git/CI and cloud administrators	W8 inventory and supplier/service approval. Verify existing scanners first. Artifact provenance and required findings must be checked before regulated production release; critical reachable issues trigger P0 containment.
G2 - configuration, environment and privileged-tool boundaries	P1; W7, W9, W10, W14	Configuration schema and secure baselines; deployed drift comparison; Git/CI protections; distinct dev/test/prod resources and credentials; explicit target checks for deployment/migration utilities. Combine policy checks with existing feature/profile/generated checks.	Platform/engineering; Git/CI administrator and cloud account owner	W8 resource inventory and W9 access policy. Put environment safeguards in place before exercising scans, probes, migrations or deployment automation. No production-target bypass in test workflows.

Group	Priority and existing packages	Integrated deliverables	Accountable / external owners	Dependencies and release condition
G3 - labels, server-side masking and screen privacy	P1; W1, W2, W4, W6, W9, W12	Propagate approved classification labels through screens, exports and metadata. Add server-side role/purpose masking and separately authorized/audited reveal. Retain visual concealment for incidental viewing and clear displayed sensitive values on session lock.	Data/privacy owner + CMS maintainer; IT/workforce owner for workstation/clear-desk policy	W1 classification, W9 access model and W4 audit. Masking policy must cover HTML, DOM attributes, JSON, exports and shared caches. If unauthorized users currently receive originals, promote that route to P0.
G4 - approval separation and trusted access paths	P1; W3, W4, W6, W9, W10	Define high-risk changes requiring independent approval; prevent self-approval and stale approvals. Integrate approved remote-access/device gateway; validate origin/egress/network-service boundaries and service health. Reuse existing roles, origin guards and plugin policy checks.	Security/platform + core maintainer; identity, gateway/network and supplier owners	Agree conflicting duties and gateway architecture first. Enforce checks at execution, including API/job paths, and obtain deployed identity/network evidence before closing hybrid rows.
G5 - requirements, architecture, coding and safe tests	P1 foundation; W7, W12, W14	A requirements-to-test register, threat/trust-boundary decisions, secure code patterns and focused static/negative tests. Synthetic test data and fixture hygiene. Audit probes use explicit target allowlists, bounded/read-only defaults, cancellation and cleanup.	Engineering lead + security reviewer; test/data owner and authorizing operations lead	Begin before remediation PRs. G2 environment isolation precedes remote testing; no authorization inferred from the presence of a probe script. Every security requirement has a reviewed acceptance test or documented verification method.
G6 - capacity, secure degradation, redundancy and time	P1 design/critical tests; P2 broader exercises; W0, W4, W5, W11	Capacity budgets, load/backpressure tests and operational metrics. Safe degraded modes and idempotent recovery/failover against dependency outages. Consistent UTC parsing, sequence-based ordering and clock-skew tests. Reuse restore drills instead of a separate resilience program.	Operations + platform/core maintainer; business continuity owner and service provider	W8 dependency map, approved RPO/RTO/capacity objectives, G2 isolated test environment and provider architecture. Failure must not bypass access or audit guarantees. Host synchronization/redundancy must be evidenced externally.
G7 - reporting, triage and containment workflow	P1; W4, W5, W9, W13	Reuse existing audit review/signals. Integrate workforce reporting and existing incident tooling; severity/assignment/acknowledgment/escalation records; audited session/plugin/route containment with recovery checks.	Incident lead + operations; workforce communications and incident-service owner	W4 event/actor contract, W5 alert delivery and W13 response authority. Prefer linking to an existing incident system over building one in CMS. Exercise report-to-resolution with human decision records.

Group	Priority and existing packages	Integrated deliverables	Accountable / external owners	Dependencies and release condition
G8 - quarantine and malware-scanner integration	P1 supplier/design; P2 rollout unless file risk makes it a release prerequisite; W2, W4, W10, W12	Add upload scan-state/quarantine and clean-only delivery to the existing private-media work. Approved scanner integration with bounded payload/time, retries, audit evidence, cleanup and integrity-bound verdicts. Preserve MIME/magic/size checks.	Media maintainer + security; scanner vendor/platform and endpoint-security owner	W10 scanner/service and PHI eligibility approval, W2 delivery inventory and W12 retention. Block affected file acceptance until required scanning is operational; do not send PHI to an unapproved scanner. Endpoint malware controls remain separate.

P1 additions do not postpone P0 containment. P2 means later rollout after risk assessment, not optional work to be forgotten. A release-critical finding moves the affected task earlier. Organizational approval, scanning service procurement or provider changes are dependencies to track, not presumed code defects.

Acceptance tests that extend the existing suites

- G1: exercise a synthetic advisory/secret/licence-policy failure through detection, triage and release blocking; verify approved exceptions expire. Confirm artifact bytes/provenance at deployment, dependency/plugin version attribution and restricted contributor credentials. A scanner report alone does not prove remediation or trustworthy provenance. Legal reviews content/IP obligations beyond dependency licences.
- G2: dev/test tooling refuses production identifiers and credentials; unauthorized users cannot bypass required Git/CI/environment checks or cloud deployment roles. Detect a safe injected configuration drift and record remediation. Audit privileged utility use without logging secrets. Configuration files alone are not evidence that account/network segmentation is enforced.
- G3: originals never reach an unauthorized client's response, DOM attributes, JSON, export or cache. Authorized reveal is server-checked, attributable and invalidated by revocation. Classification labels survive approved export/metadata transformations without leaking sensitive filenames/identifiers. Session lock clears visible values, but workstation/desk safeguards still need IT evidence.
- G4: reject proposer self-approval through UI/API and queued execution; a changed proposal invalidates prior approval. Test revoked approver privileges and emergency-exception evidence. Exercise alternate-origin/provider bypass and SSRF/egress restrictions, including redirects and permitted localhost-only development behavior. Validate actual gateway policy and network-service obligations, not merely HTTPS URL syntax.
- G5: trace requirements to passing negative tests; use synthetic PHI/secrets to test fixture scanning and sanitization. Check parser/XSS/SSRF/authorization boundaries with meaningful adversarial cases. Restrict security tools to approved targets, request budgets and credentials; demonstrate cancellation/cleanup in staging. Automated detection is not proof that all test data is safe.
- G6: run representative load and dependency-loss scenarios against approved limits. Demonstrate bounded queues/retries, no duplicate committed operations and recoverability within agreed objectives. Verify degraded operation stays protected; exercise stale/reordered timestamps and concurrent events without assuming unique wall-clock values. Provider evidence and failover tests establish the actual redundancy/clock boundary; do not implement

host NTP in a Worker.

- G7: deliver a test report/signal to an assigned responder, record severity and decisions, perform authorized containment and verify restoration. Limit report content/attachments and access so the reporting channel does not become a PHI leak. Record corrective follow-up through W13.
- G8: test clean, malicious-test, pending, timeout, unavailable and contradictory scanner outcomes in an isolated environment. Bind each verdict to immutable object version/hash; replacement requires a new scan. All original/thumbnail/export/plugin/direct-storage paths must deny quarantined content. Enforce idempotent completion, bounded retries and safe expiry; no "scanner down means clean" fallback. Close the CMS integration and endpoint/provider malware evidence separately.

Added-control traceability: exactly 32 controls

ISO control	Delivery	Primary group / existing packages	Closure evidence beyond the shared group tests
A.5.3	R	G4 / W3, W4, W9	Approved conflicting-duties policy and effective independent approval of selected high-risk changes
A.5.7	H	G1 / W8, W10, W14	Relevant feeds mapped to deployed assets, named analyst triage and recorded action
A.5.13	R	G3 / W1, W12	Approved label scheme with tested propagation and handling guidance
A.5.21	R	G1 / W10, W14	SBOM/provenance, approved supplier/artifact intake and dependency/plugin change review
A.5.25	H	G7 / W5, W13	Human severity/incident determination and accountable decision records
A.5.26	H	G7 / W4, W9, W13	Authorized containment, recovery and documented response outcomes
A.5.29	H	G6 / W11	Approved secure emergency operation and tested disruption behavior
A.5.32	R	G1 / W10, W14	Licence notices/policy checks plus legal confirmation of applicable software/content rights
A.5.36	R	G2 / W7, W14	Automated policy checks plus human review and controlled, time-bounded exceptions
A.6.7	H	G4 / W9, W10	Verified remote gateway/device controls and approved remote-work procedures
A.6.8	H	G7 / W13	Accessible reporting channel, workforce instructions and demonstrated response
A.7.7	H	G3 / W6, W9, W12	App concealment/locking plus implemented clear-desk/workstation rules
A.8.4	H	G2 / W9, W14	Git-host membership/branch controls, bypass restrictions and review records
A.8.6	R	G6 / W0, W5, W11	Capacity/load budgets, measured tests, metrics and assigned scaling/alert response
A.8.7	H	G8 / W2, W4, W10	Approved scanner, protected quarantine/delivery and external malware safeguards
A.8.8	R	G1 / W10, W14	Vulnerability inventory, scanning, triage, deadlines and verified remediation/exception handling
A.8.9	R	G2 / W7, W14	Configuration baseline and observed deployed drift detection/remediation
A.8.11	R	G3 / W1, W4, W9, W12	Approved masking policy and no original values delivered to unauthorized users

ISO control	Delivery	Primary group / existing packages	Closure evidence beyond the shared group tests
A.8.14	H	G6 / W10, W11	Actual provider/service redundancy architecture and demonstrated failover against objectives
A.8.17	H	G6 / W4, W11	Provider clock assurance and verified UTC/ordering/skew behavior
A.8.18	H	G2 / W9, W14	Restricted cloud/DB/CI utility access with explicit targets and audit evidence
A.8.19	H	G1 / W9, W14	Approved immutable artifacts and enforced production-install/deployment permissions
A.8.20	H	G4 / W9, W10	Application egress/boundary tests plus deployed gateway/network policy
A.8.21	H	G4 / W10	Secure network-service configuration, provider assurance and service review
A.8.22	H	G2 / W9, W10, W14	Verified service/account/network isolation, not just separate table or binding names
A.8.26	R	G5 / W7, W14	Approved application-security requirements linked to acceptance evidence
A.8.27	R	G5 / W9, W14	Reviewed trust/data-flow design and enforced engineering/least-privilege boundaries
A.8.28	R	G5 / W7, W14	Adopted coding patterns, meaningful checks and review of representative changes
A.8.30	H	G1 / W10, W14	Where applicable: vendor terms, restricted contributor access and approved deliverable review
A.8.31	H	G2 / W7, W9, W14	Isolated resources/data/credentials plus enforced CI environment permissions
A.8.33	R	G5 / W7, W12, W14	Synthetic/minimized fixtures and approved, protected test-information lifecycle
A.8.34	H	G5 / W7, W14	Explicit audit-test authorization, protected targets/data, monitored execution and cleanup

Revised execution sequence and control accounting

1. Baseline and protect: refresh the gap assessment against current code; extend the W8 register from 27 to 59 IDs; assign one owner and reviewer per ID. Identify implemented external CI, gateway, scanner and incident services. Keep W0/P0 containment first. Start W10 external approvals immediately.

2. Establish safe delivery: start G1/G2/G5 before remediation automation or remote tests. These extend W14/W7 rather than waiting until the end. Enforce target isolation, core checks and approved artifacts; tune newly introduced gates in staging without indefinitely bypassing them in production.

3. Implement shared data/access safeguards: deliver remaining W1-W4/W6 fixes together with G3/G4. Share classification, permission, proposal/version and durable-event contracts. Split migrations and narrowly scoped PRs within each package; do not create one monolithic security release.

4. Integrate operations: complete W5/W11/W13 with G6/G7. Run load/failure, review/containment, recovery and clock-ordering scenarios. Use the same evidence records for overlapping controls.

5. Release protected uploads: implement G8 after scanner eligibility and private delivery are verified. If scanning is required for the workload before launch, disable affected uploads until this gate passes rather than defer the protection.

6. Integrated closure: W7 validates each group against the exact deployed revision; review the 27 original and 32 added rows. Require both repository and external evidence for every hybrid row. Track repo-ready, external-ready and reviewed-effective separately; report implemented, open and justified-inapplicable counts without counting exclusions as implementation.

The 59-control figure is planned coverage, not an achieved count or 59 separate code changes. The 13 repo-led additions also need policies/operating evidence where stated. The 19 hybrid additions cannot close on a merged PR alone. Existing HIPAA work remains in scope; shared data, access, audit, incident and recovery improvements support it without inventing a one-to-one legal equivalence.

Sizing and decisions before scheduling

The earlier 48-88 person-day allowance is retained only as the original 27-control baseline, not a budget for all 59. Size incremental G1-G8 tasks after baseline reconciliation: deduct work already implemented in W1-W14 and reuse current external tooling. Do not add a second complete estimate for CI, access policy, restores or incident integration already included there. No defensible revised total or delivery date is claimed before that reconciliation.

Required decisions: selected CI/scanning and incident systems; approved gateway and environment boundaries; masking/reveal and independent-approval policy; capacity/recovery objectives; scanner service eligibility and affected file types; evidence owners and operational review cadence. Unknowns remain tracked dependencies, not assumed permissions, completed controls or reasons to stop independent planning. Supplier lead time, new infrastructure and provider contract changes must be estimated separately from engineering effort.

Plan validation

The remaining-66-control feasibility evaluation, performed at 2e6965e, identifies 13 repo-led engineering controls, 19 hybrid controls, 17 documentation/process controls and 17 principally external controls. The 32 engineering/hybrid controls are now integrated explicitly in G1-G8 and assigned exactly once in the added-control traceability table. The original 27 remain mapped: total planned coverage is 59 unique IDs. The older "not relevant" placeholders in the ISO matrix have been replaced with feasibility categories. Formal applicability and operational evidence still require assessment. New regulated-publication/media code was observed during that evaluation; refresh W1-W3 against that revision before duplicating implementation.

The targeted source paths and existing audit-review implementation were inspected at e50a467. Only documentation was changed to create this plan; no new runtime test result, remediation, deployment or contract verification is claimed.